

AI DOCTOR

Implementacao de Seguranca

JWT, RBAC com 3 papeis, Helmet/CORS, rate limiting, S3 seguro, validacao de entrada, e 30 stress tests de seguranca.

Versao 3.0 | Julho 2026

1. Autenticação e Autorização

O sistema implementa autenticação stateless via JWT (JSON Web Tokens) com três níveis de controle de acesso baseado em papéis (RBAC): Paciente, Médico e Admin. Cada token JWT contém o ID do usuário, email, e role, com tempo de expiração configurável. O hashing de senhas utiliza bcryptjs com salt rounds configurados para proteção contra ataques de força bruta.

O middleware de autenticação valida o token JWT em cada requisição protegida, verificando assinatura, expiração e integridade. O RBAC restringe acesso a endpoints específicos por papel: pacientes acessam próprios dados e telemedicina, médicos acessam juntas médicas e diagnóstico, admins gerenciam o sistema completo. A sessão é gerenciada via refresh tokens para renovação transparente.

Recurso	Paciente	Médico	Admin
Dashboard Principal	Sim	Sim	Sim
Junta Médica PhD	Não	Sim	Sim
Diagnósticos	Próprio	Todos	Todos
Telemedicina	Sim	Sim	Sim
Gerenciar Usuários	Não	Não	Sim
Configuração Sistema	Não	Não	Sim

2. Headers de Segurança e Proteção

O servidor Express utiliza Helmet como middleware de segurança padrão, configurando automaticamente headers de proteção como X-Content-Type-Options, X-Frame-Options, Strict-Transport-Security, e Content-Security-Policy. A configuração do CORS restringe origens permitidas, métodos HTTP, e headers expostos para cada ambiente (desenvolvimento, staging, produção).

O rate limiting protege contra abuso com limites configuráveis por endpoint e por IP. O sistema implementa cooldown progressivo para tentativas repetidas de login falhas, bloqueio temporário após exceder limites, e burst tolerance para picos legítimos de tráfego. Todos os 10 stress tests de Security Headers validam a integridade destas proteções sob carga.

3. Armazenamento S3 Seguro

O upload de arquivos utiliza AWS S3 com assinaturas presigned URL que expiram após uso, eliminando a necessidade de expor credenciais AWS no frontend. O router S3 valida tipo e tamanho do arquivo antes do upload, restringindo formatos aceitos e limites de tamanho. Todos os arquivos de exames e relatórios são armazenados com criação de buckets separados por ambiente e controle de acesso granular via IAM policies.

4. Validação de Entrada e Sanitização

Todas as entradas de usuário são validadas via Zod schemas no lado do servidor (tRPC) e no lado do cliente (React). O sistema previne injeção XSS sanitizando HTML em campos de texto, previne injeção SQL via ORM (Drizzle) com

queries parametrizadas, e valida boundary conditions em todos os campos numericos. Os 10 stress tests de Input Validation cobrem payloads maliciosos, dados invalidos e boundary testing.

5. Nginx Reverse Proxy

O Nginx atua como reverse proxy com SSL/TLS termination, load balancing, e protecao DDoS basica. A configuracao inclui timeouts otimizados para requisicoes de IA (que podem levar mais tempo), headers de seguranca adicionais no nivel do proxy, e compressao gzip para respostas grandes. O docker-compose de producao integra Nginx como container separado com mount do certificado SSL.